

API Security Risk Analysis Report

Prepared By

Sakshi Atole

Date

June 2026

Tools Used

- Postman
 - Browser Developer Tools
 - Microsoft Word
 - GitHub
-

1. Executive Summary

This report presents a security risk assessment of the JSONPlaceholder public API. The assessment was conducted using a read-only methodology to identify common API security risks related to authentication, authorization, data exposure, and security best practices.

The objective of this assessment was to evaluate the API from a security consultant's perspective and identify potential risks that could affect confidentiality, integrity, and availability if similar configurations were present in a production environment.

2. Scope of Assessment

Target API

<https://jsonplaceholder.typicode.com>

Assessment Type

Read-Only API Security Risk Analysis

In Scope

- Endpoint discovery
- Authentication review
- Authorization review

- Response analysis
- Header inspection
- Data exposure analysis

Out of Scope

- Exploitation attempts
- Denial-of-Service testing
- Vulnerability exploitation
- Privilege escalation
- Production system attacks

3. Methodology

The following methodology was used during the assessment:

1. Review API documentation.
2. Identify publicly accessible endpoints.
3. Test endpoints using Postman.
4. Analyze response data.
5. Review authentication mechanisms.
6. Inspect request and response headers.
7. Identify potential security risks.
8. Classify risks based on severity.
9. Recommend remediation measures.

4. Tested Endpoints

Endpoint	Method	Purpose
/comments	GET	Retrieve comments
/users	GET	Retrieve user information
/users/1	GET	Retrieve individual user
/users/2	GET	Retrieve individual user
/posts	GET	Retrieve posts

5. Security Findings

Finding 1: Unauthenticated Access to API Endpoints

Observation

The API endpoints can be accessed without requiring authentication, API keys, or user credentials.

Evidence

Requests to /comments and /users returned successful responses without authentication.

Business Impact

If deployed in a production environment, unauthorized users could access data without identity verification, increasing the risk of information disclosure.

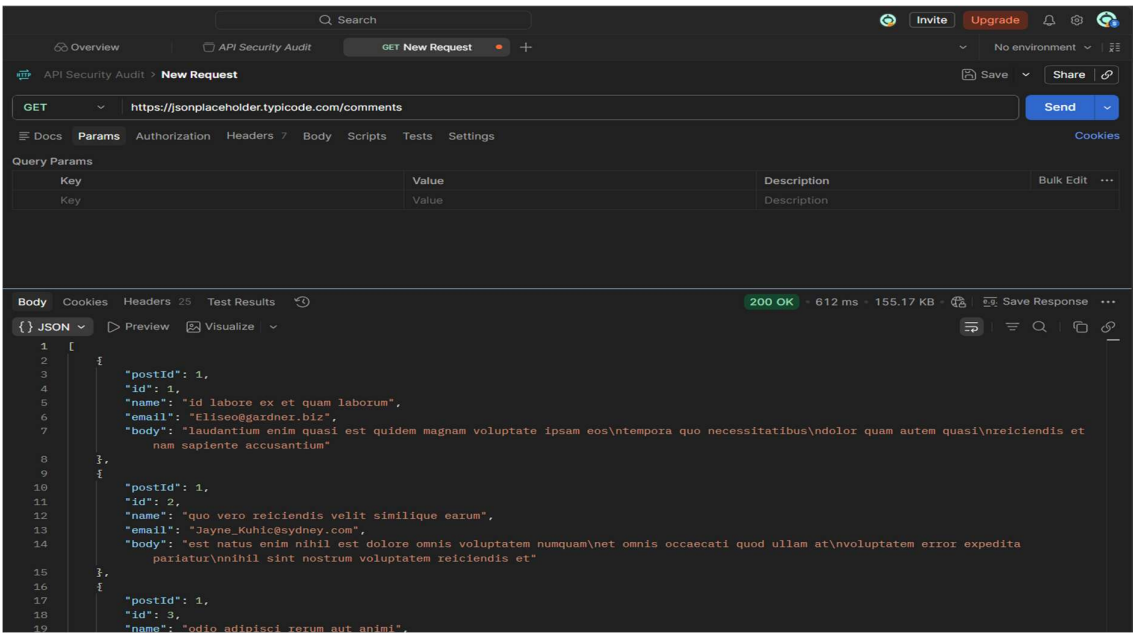
Severity

Medium

Recommendation

Implement authentication mechanisms such as API Keys, JWT tokens, or OAuth 2.0 before granting access to sensitive resources.

Screenshot:



Finding 2: Excessive Data Exposure

Observation

The /users endpoint returns detailed information including email addresses, phone numbers, addresses, company details, and websites.

Evidence

The API response exposed multiple user attributes that may not be required by all consumers.

Business Impact

Excessive data exposure can aid phishing campaigns, social engineering attacks, and privacy violations.

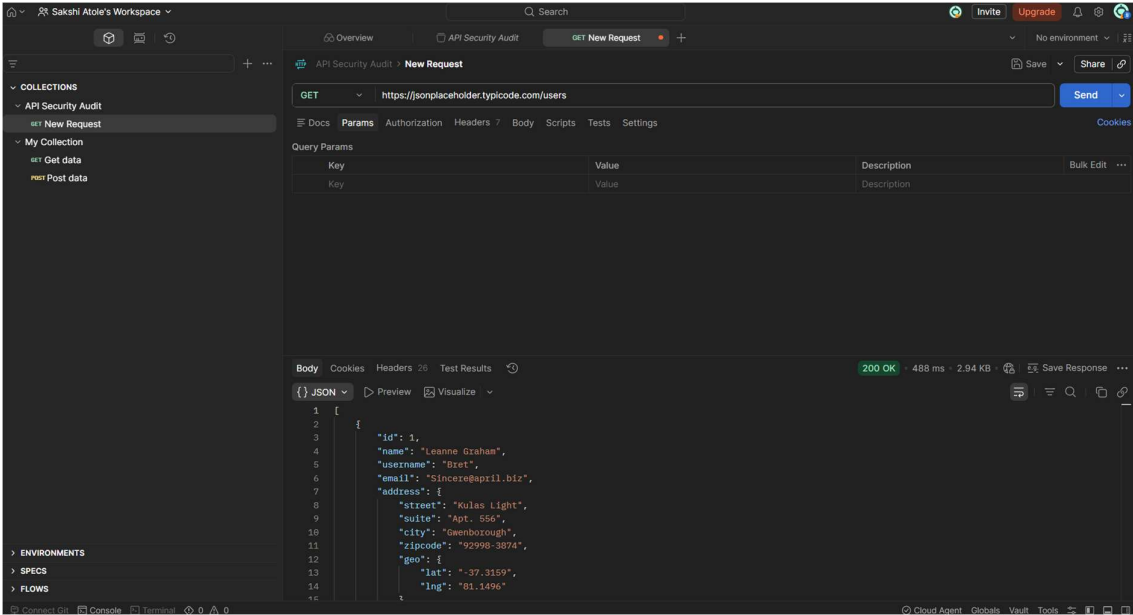
Severity

Medium

Recommendation

Apply data minimization principles and return only necessary fields required by clients.

Screenshot



Finding 3: Weak Access Control Validation

Observation

Individual user records can be accessed directly through predictable URLs such as /users/1 and /users/2.

Evidence

User records were accessible without any verification mechanism.

Business Impact

In production systems, insufficient access control could allow users to access resources belonging to other users.

Severity

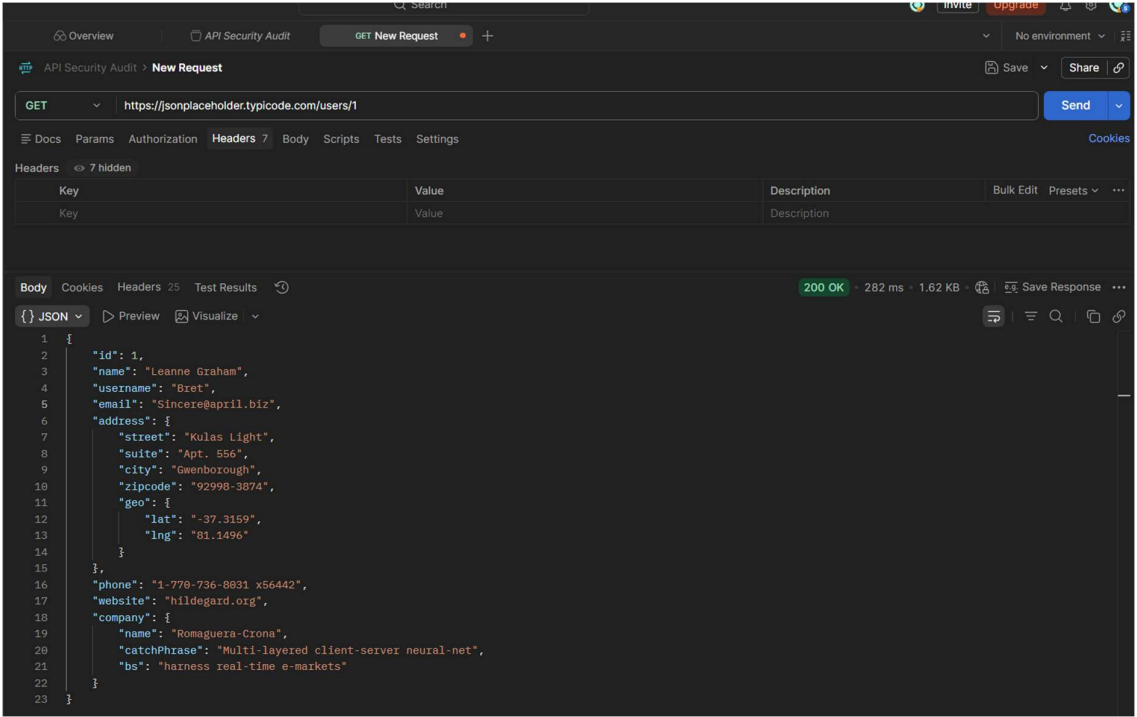
Medium

Recommendation

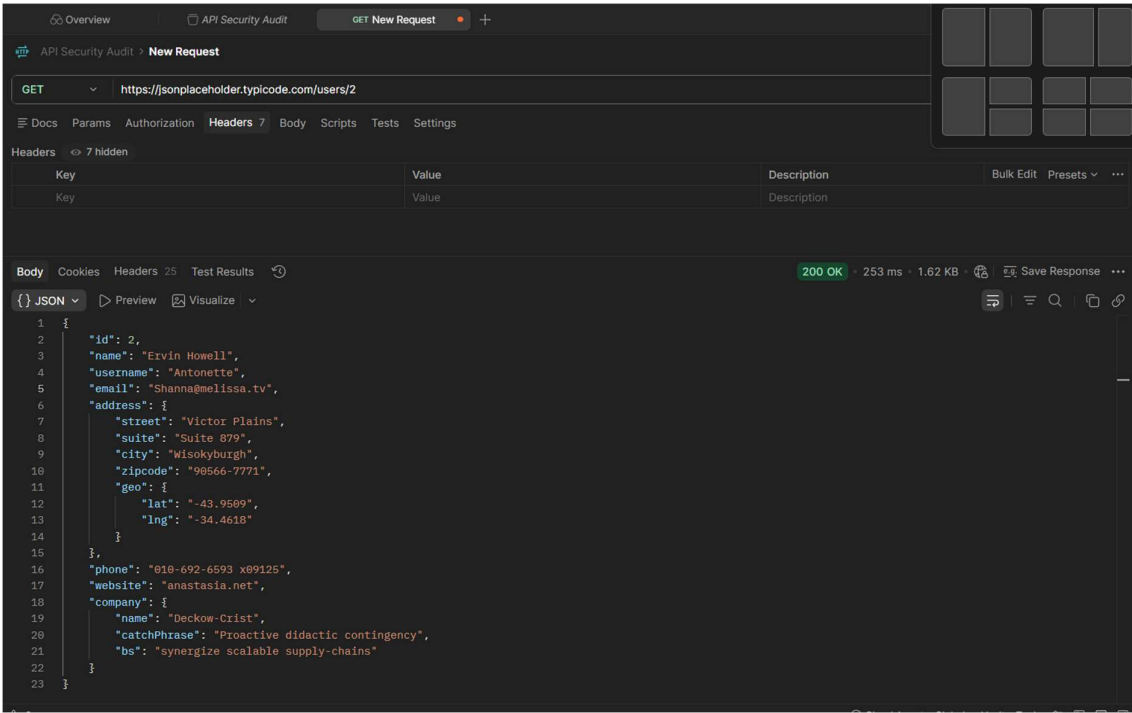
Implement Role-Based Access Control (RBAC) and verify user authorization before returning resources.

Screenshot

USER 1:



USER 2:



Finding 4: Missing Authentication Tokens

Observation

No authentication token or authorization mechanism was observed during testing.

Evidence

Requests succeeded without Authorization headers.

Business Impact

The absence of token-based authentication weakens security controls and increases exposure to unauthorized access.

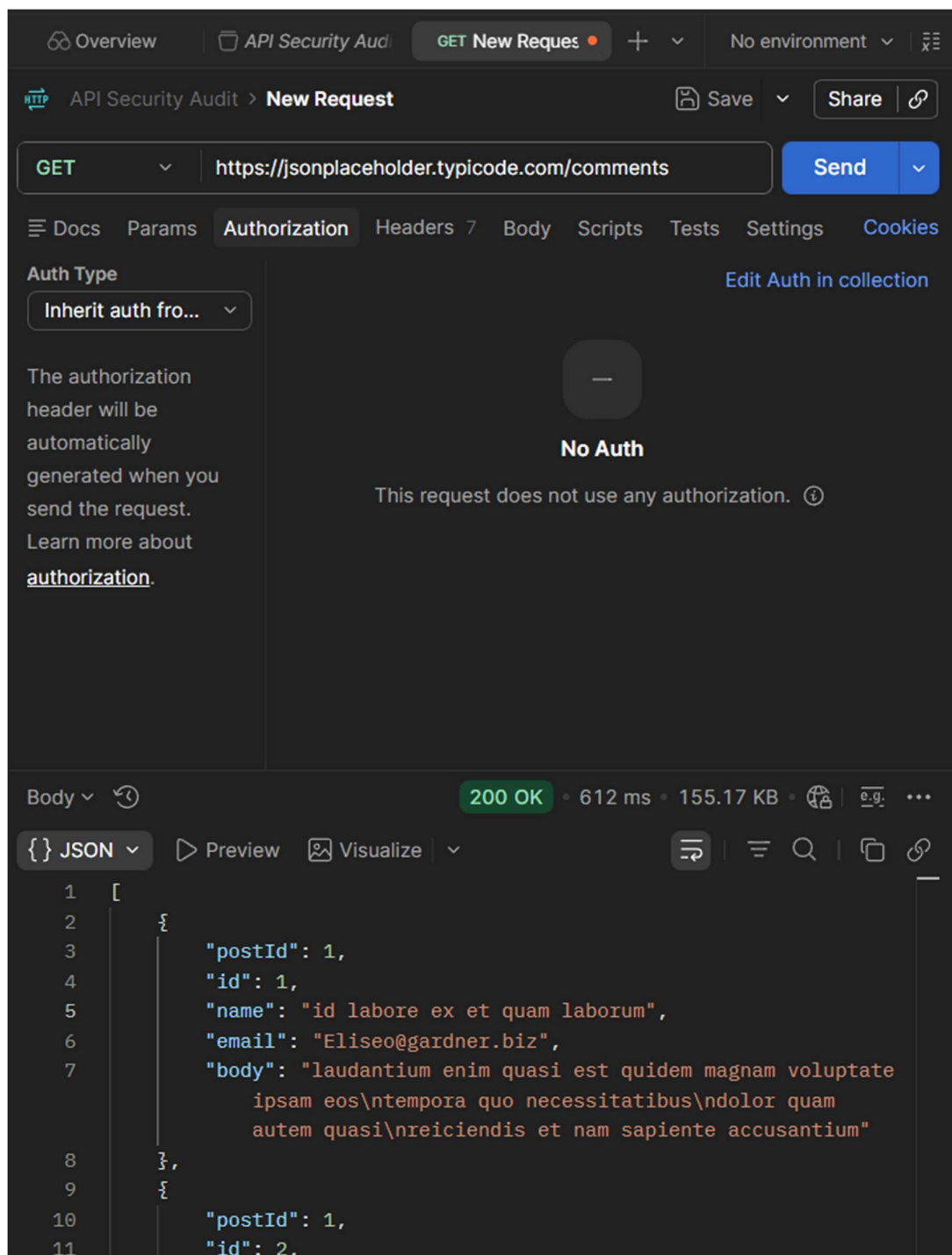
Severity

Medium

Recommendation

Adopt secure token-based authentication using JWT or OAuth 2.0 standards.

Screenshot



Finding 5: Potential Absence of Rate Limiting

Observation

No visible rate-limiting controls were observed during the assessment.

Evidence

The API documentation and responses did not indicate request throttling controls.

Business Impact

Lack of rate limiting could enable abuse, automated scraping, or resource exhaustion attacks.

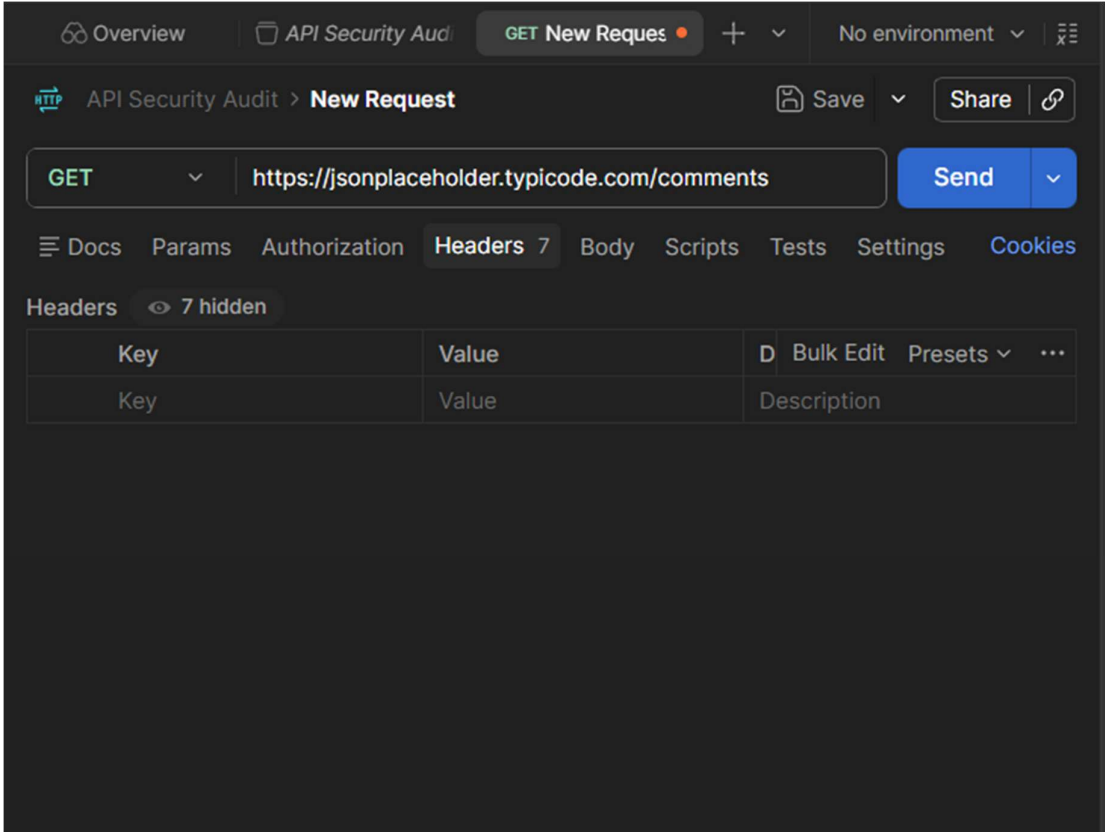
Severity

Low

Recommendation

Implement request throttling and API rate limits to prevent abuse.

Screenshot



6. Risk Summary

Risk ID	Finding	Severity
R1	Unauthenticated User	Medium
R2	Excessive Data Exposure	Medium
R3	Weak Access Control	Medium

R4	Missing Authentication Tokens	Medium
R5	Missing Rate Limiting	Low

7. Risk Matrix

Severity	Number of Findings
High	0
Medium	4
Low	1

8. Recommendations

The following security improvements are recommended:

1. Implement API authentication using OAuth 2.0 or JWT.
 2. Apply Role-Based Access Control (RBAC).
 3. Reduce unnecessary exposure of user information.
 4. Implement API rate limiting.
 5. Continuously monitor API activity and access logs.
 6. Conduct periodic API security reviews aligned with OWASP API Security Top 10 guidelines.
-

9. Conclusion

The assessment identified several common API security risks including unauthenticated access, excessive data exposure, weak access control validation, and the absence of visible rate-limiting mechanisms. While the JSONPlaceholder API is intentionally designed as a public testing platform, similar configurations in production environments could introduce significant security concerns.

Implementing strong authentication, authorization controls, data minimization practices, and rate limiting would significantly improve the security posture of an API-based application.

Appendix

Tools Used

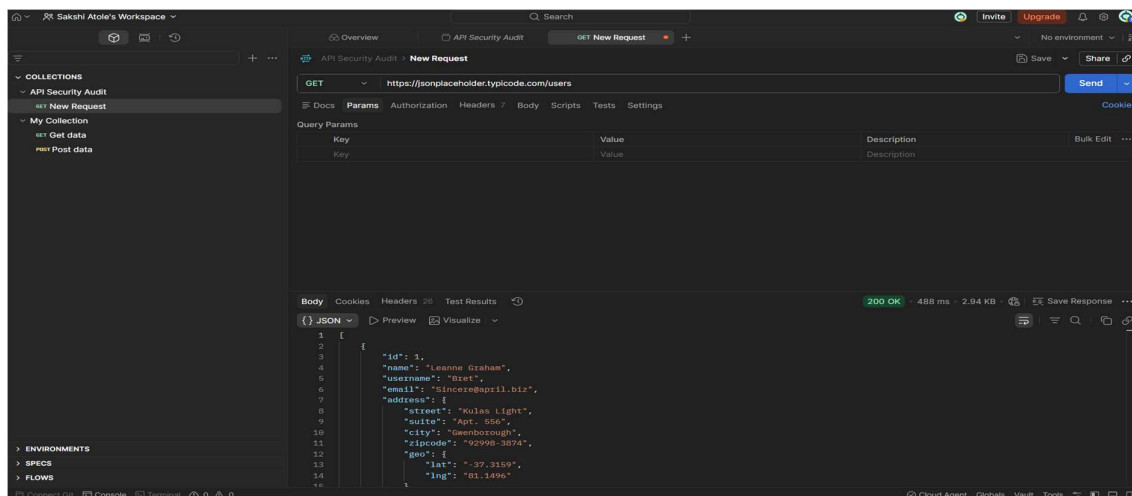
- Postman
- Browser Developer Tools
- GitHub

Reference Frameworks

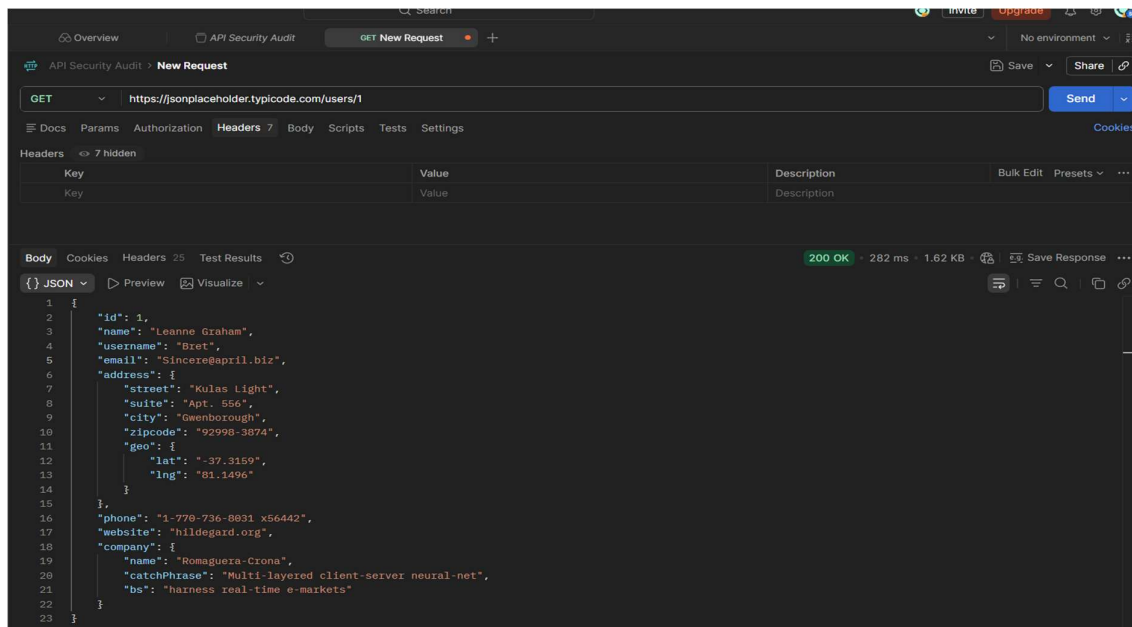
- OWASP API Security Top 10
- API Security Best Practices

Screenshots

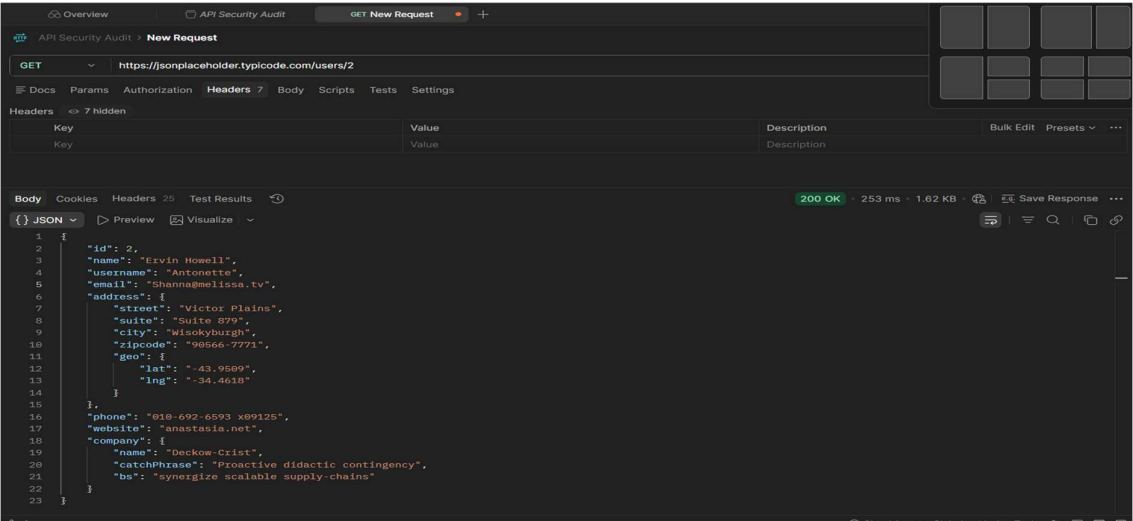
Test Endpoint 1: USERS



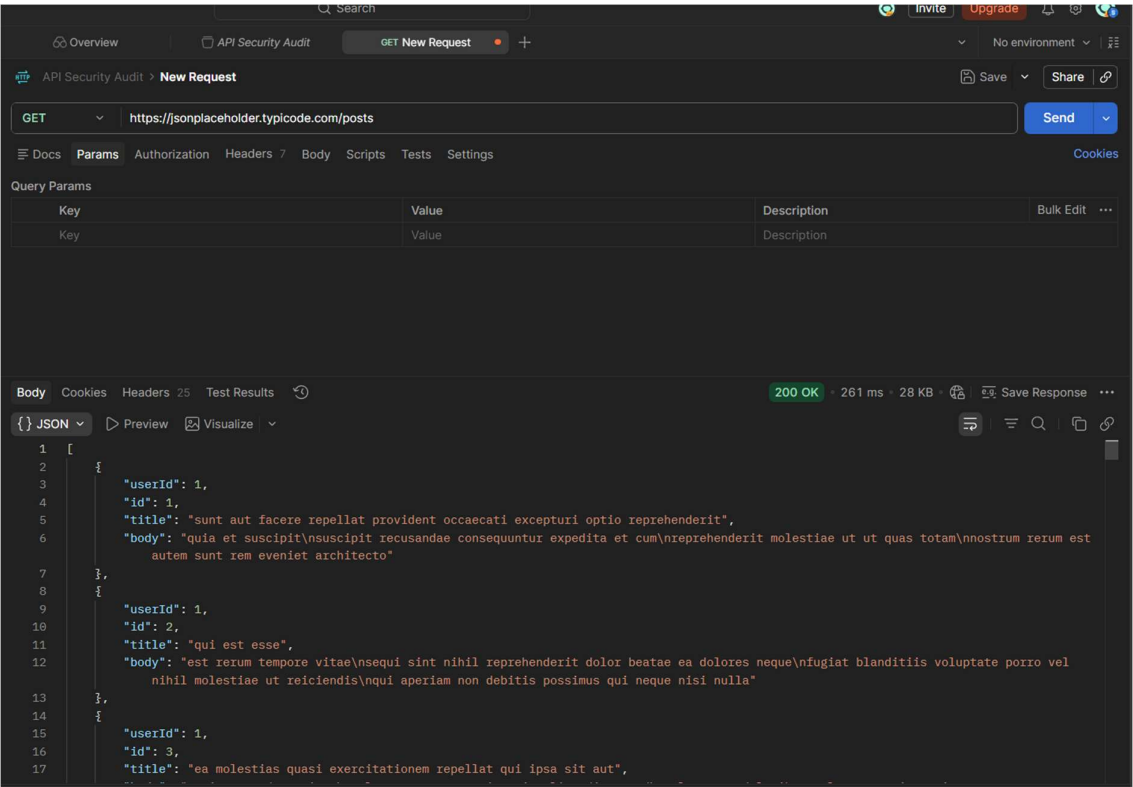
USER 1:



USER 2:



Test Endpoint 2: POSTS



Test Endpoint 3: COMMENTS

GET `https://jsonplaceholder.typicode.com/comments` Send

Query Params

Key	Value	Description	Bulk Edit
Key	Value	Description	

Body 200 OK 612 ms 155.17 KB Save Response

`{}` JSON Preview Visualize

```
1 [
2   {
3     "postId": 1,
4     "id": 1,
5     "name": "id labore ex et quam laborum",
6     "email": "Eliseo@gardner.biz",
7     "body": "laudantium enim quasi est quidem magnam voluptate ipsam eos\ntempora quo necessitatibus\ndolor quam autem quasi\nreiciendis et nam sapiente accusantium"
8   },
9   {
10    "postId": 1,
11    "id": 2,
12    "name": "quo vero reiciendis velit similique earum",
13    "email": "Jayne_Kuhic@sydney.com",
14    "body": "est natus enim nihil est dolore omnis voluptatem numquam\nnet omnis occaecati quod ullam at\nvoluptatem error expedita pariatur\nnnihil sint nostrum voluptatem reiciendis et"
15  },
16  {
17    "postId": 1,
18    "id": 3,
19    "name": "odio adipisci rerum aut animi",
```

Authorization:

Overview API Security Audit GET New Request No environment

API Security Audit > **New Request** Save Share

GET `https://jsonplaceholder.typicode.com/comments` Send

Docs Params **Authorization** Headers 7 Body Scripts Tests Settings Cookies

Auth Type Inherit auth fro... Edit Auth in collection

The authorization header will be automatically generated when you send the request. [Learn more about authorization.](#)

No Auth
This request does not use any authorization.

Body 200 OK 612 ms 155.17 KB Save Response

`{}` JSON Preview Visualize

```
1 [
2   {
3     "postId": 1,
4     "id": 1,
5     "name": "id labore ex et quam laborum",
6     "email": "Eliseo@gardner.biz",
7     "body": "laudantium enim quasi est quidem magnam voluptate ipsam eos\ntempora quo necessitatibus\ndolor quam autem quasi\nreiciendis et nam sapiente accusantium"
8   },
9   {
10    "postId": 1,
11    "id": 2,
```

Headers

Overview

API Security Audit

GET New Request

+

▼

No environment

▼

≡

HTTP

API Security Audit > New Request

Save

▼

Share

🔗

GET

▼

https://jsonplaceholder.typicode.com/comments

Send

▼

☰ Docs

Params

Authorization

Headers 7

Body

Scripts

Tests

Settings

Cookies

Headers

👁 7 hidden

Key	Value	D	Bulk Edit	Presets ▼	...
Key	Value				Description